

Clase 224 — Seguridad en Azure

Parte: **10 — Seguridad en la nube y contenedores** · Fuente: *Microsoft Cloud Security Benchmark y documentación oficial de Microsoft Defender for Cloud* 🕒 Duración estimada: **120 min** · Nivel: **Intermedio**

Objetivo

Asegurar una suscripción de Azure aplicando su modelo de identidad (Microsoft Entra ID), control de acceso (RBAC), gobierno (Azure Policy y Management Groups), red (NSG, Firewall) y los servicios de seguridad gestionados (Defender for Cloud, Sentinel). Al terminar, el alumno sabrá endurecer una suscripción según el Microsoft Cloud Security Benchmark.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Modelar** identidades y accesos con Entra ID y Azure RBAC.
2. **Aplicar** gobierno con Azure Policy y jerarquía de Management Groups.
3. **Segmentar** red con NSG, subredes y Azure Firewall.
4. **Interpretar** el Secure Score y las recomendaciones de Defender for Cloud.
5. **Proteger** secretos y claves con Azure Key Vault.

Temas

#	Tema	Por qué importa
1	Entra ID (antes Azure AD)	Directorio y autenticación de toda la nube Microsoft
2	Azure RBAC y roles	Control de acceso a recursos por ámbito
3	Management Groups y Azure Policy	Gobierno y cumplimiento a escala
4	Network Security Groups y Firewall	Segmentación y filtrado de tráfico
5	Defender for Cloud y Secure Score	Postura y detección de amenazas
6	Key Vault	Gestión de secretos, claves y certificados
7	Microsoft Sentinel	SIEM/SOAR nativo en la nube

Definiciones y características

- **Microsoft Entra ID:** servicio de identidad de Azure. *Clave:* MFA y Conditional Access son la primera línea de defensa.
- **Azure RBAC:** asignación de roles (Owner, Contributor, Reader...) por ámbito. *Clave:* el ámbito puede ser suscripción, grupo de recursos o recurso.

- **Management Group:** contenedor jerárquico de suscripciones. *Clave:* permite aplicar policy heredada a toda la organización.
- **Azure Policy:** reglas que auditan o fuerzan configuraciones. *Clave:* efecto **Deny** bloquea despliegues no conformes.
- **NSG:** firewall stateful sobre subred o NIC. *Clave:* reglas por prioridad; la más baja gana.
- **Defender for Cloud:** CSPM + protección de cargas. *Clave:* el Secure Score cuantifica la postura.
- **Key Vault:** almacén gestionado de secretos y claves. *Clave:* acceso vía RBAC/policy y auditado.

Herramientas y preparación

- CLI **az** autenticada en una suscripción de laboratorio.
- **ScoutSuite** con el proveedor **azure** para auditoría.
- **Prowler** también soporta Azure (**prowler azure**).

```
# Listar asignaciones de rol en la suscripción
az role assignment list --all -o table
# Ver el estado de Defender for Cloud
az security pricing list -o table
```

Laboratorio guiado

1. Crea un grupo de recursos de laboratorio y asigna a un usuario el rol **Reader** solo en ese ámbito; verifica que no puede crear recursos.
2. Habilita **MFA** y una política de **Conditional Access** que exija MFA para roles administrativos.
3. Define un **Management Group** y aplica una **Azure Policy** que deniegue la creación de cuentas de almacenamiento con acceso público. Intenta crear una y confirma el **Deny**.
4. Crea una VNet con dos subredes y un **NSG** que permita solo HTTPS entrante; asocia el NSG a la subred.
5. Habilita **Defender for Cloud** en la suscripción, revisa el **Secure Score** y aplica tres recomendaciones prioritarias.
6. Crea un **Key Vault**, guarda un secreto y concede acceso a una identidad administrada (managed identity) en vez de credenciales estáticas.
7. Ejecuta **scout azure** o **prowler azure --compliance cis_2.0_azure** y corrige los hallazgos altos de red y almacenamiento.

Ejercicios

1. Asigna un rol personalizado que permita solo iniciar/detener VMs, sin borrarlas.
2. Escribe una Azure Policy que exija etiquetas obligatorias en todos los recursos.
3. Configura un NSG con reglas por prioridad y explica cuál gana ante un conflicto.
4. Integra una managed identity para que una VM lea un secreto de Key Vault sin credenciales.
5. Conecta Defender for Cloud a Microsoft Sentinel y crea una regla de detección.
6. Interpreta una recomendación de Secure Score y estima su impacto en la puntuación.

Reto verificable

Endurece una suscripción de laboratorio: MFA obligatorio para admins, una Azure Policy de **Deny** sobre almacenamiento público aplicada por Management Group, Defender for Cloud activo y un Key Vault con

acceso solo por managed identity.

Criterio de aceptación: intentar crear una cuenta de almacenamiento pública es bloqueado por la policy, el Secure Score sube respecto al estado inicial, y `prowler azure` reporta como `PASS` los controles de MFA y almacenamiento.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Rol asignado pero sin permisos esperados	Ámbito equivocado; verifica si se asignó a recurso, grupo o suscripción.
Policy no bloquea despliegues	Efecto en <code>Audit</code> en vez de <code>Deny</code> ; cambia el efecto y reasigna.
NSG "no aplica" a una VM	Regla de menor prioridad la anula, o el NSG está en la subred equivocada.
Secreto en el código de la app	No se usó Key Vault + managed identity; migra y rota el secreto.
Secure Score estancado	Recomendaciones marcadas como exentas; revisa exenciones y aplica los controles.

? Preguntas frecuentes

? **¿Cuál es la diferencia entre roles de Entra ID y roles de Azure RBAC?** Los roles de Entra ID gobiernan el directorio (usuarios, grupos, apps); los de Azure RBAC gobiernan recursos (VMs, storage). Un Global Admin de Entra no es automáticamente Owner de recursos.

? **¿Defender for Cloud tiene coste?** El nivel CSPM básico es gratuito; los planes de protección de cargas (servidores, contenedores, bases de datos) se facturan por recurso. Actívalos según el riesgo.

? **¿Managed identity o service principal con secreto?** Managed identity siempre que sea posible: Azure gestiona y rota las credenciales automáticamente, sin secretos que se filtren.

🔗 Referencias

- Microsoft Cloud Security Benchmark. <https://learn.microsoft.com/security/benchmark/azure/>
- Microsoft Defender for Cloud docs. <https://learn.microsoft.com/azure/defender-for-cloud/>
- Azure RBAC docs. <https://learn.microsoft.com/azure/role-based-access-control/>
- Azure Key Vault best practices. <https://learn.microsoft.com/azure/key-vault/general/best-practices>
- CIS Microsoft Azure Foundations Benchmark. <https://www.cisecurity.org/benchmark/azure>

➡ Siguiente clase

Clase 225 - Seguridad en Google Cloud Platform